VULNERABILITY MANAGEMENT



$ WHOAMI

- Studies
  - ELTE, Applied Mathematics
  - EIT, Advanced Cryptography
  - ELTE, Symbolic and Numeric Computation
- Work
  - Security Engineer, Python/C++
  - Cyber Security Consultant, EY
  - Red Team Member/Penetration Tester, IBM
  - Application Security Engineer, Diligent/Brainloop
- Certs
  - Offensive Security Certified Professional
  - Certified Red Team Professional
  - Offensive Security Experienced Penetration Tester



WHO IS A HACKER?

hacker: n.
[originally, someone who makes furniture with an axe]

1. A person who enjoys exploring the details of programmable systems and how to stretch their capabilities
2. One who programs enthusiastically (even obsessively) or who enjoys programming
3. A person capable of appreciating hack value.
4. A person who is good at programming quickly.
5. An expert at a particular program, or one who frequently does work using it or on it; as in 'a Unix hacker'.
6. An expert or enthusiast of any kind. One might be an astronomy hacker, for example.
7. One who enjoys the intellectual challenge of creatively overcoming or circumventing limitations.
8. [deprecated] A malicious meddler who tries to discover sensitive information by poking around.



WHO IS AN ETHICAL HACKER?

ethical hacker: n.

[originally, someone who makes furniture with an axe]

1. A person who enjoys exploring the details of programmable systems and how to stretch their capabilities
2. One who programs enthusiastically (even obsessively) or who enjoys programming
3. A person capable of appreciating hack value.
4. A person who is good at programming quickly.
5. An expert at a particular program, or one who frequently does work using it or on it; as in 'a Unix hacker'.
6. An expert or enthusiast of any kind. One might be an astronomy hacker, for example.
7. One who enjoys the intellectual challenge of creatively overcoming or circumventing limitations.
8. [deprecated] ~~A malicious meddler~~ An ethical professional who tries to discover sensitive information and evaluates the security posture of a client by ~~poking around~~ mimicking a real attacker.



SECURITY PERSONNEL IN AN ORGANIZATION

- Red Team
  - IT Security Analyst
    - Application Testing
    - Infrastructure Testing
    - Red Teaming
- Blue Team
  - Information Security Officer (ISO)
  - Security Engineer
  - Security Architect
  - Security Operations Centre
  - Monitoring



WHY DO YOU NEED ETHICAL HACKERS?

It's a **requirement** for doing **business**

- It can be a **regulatory** requirement (financial institutions, healthcare, critical infrastructure etc.)
- It can be **required** by **business partners** depending on their profile

It's **needed** to **limit** operational **risk**

- Your business **depends** on **trade secrets**, **sensitive information** that you want to **protect** (confidentiality)
- Your business **depends** on the **accuracy** of certain **information** (integrity)
- Your business **depends** highly on **access** to online **services** (availability)
- Your business **depends** highly on **reputation** (technology companies, financial institutions)



WHAT IS A VULNERABILITY?

- ***„the quality of being vulnerable (= able to be easily hurt, influenced, or attacked), or something that is vulnerable" – Cambridge Dictionary***

- ***„In computer security, a vulnerability is a weakness which can be exploited by a threat actor, such as an attacker, to perform unauthorized actions within a computer system." – Wikipedia***

- ***Attack surface – A point of the system which is „significantly weaker than the rest"***



WHAT IS AN EXPLOIT?

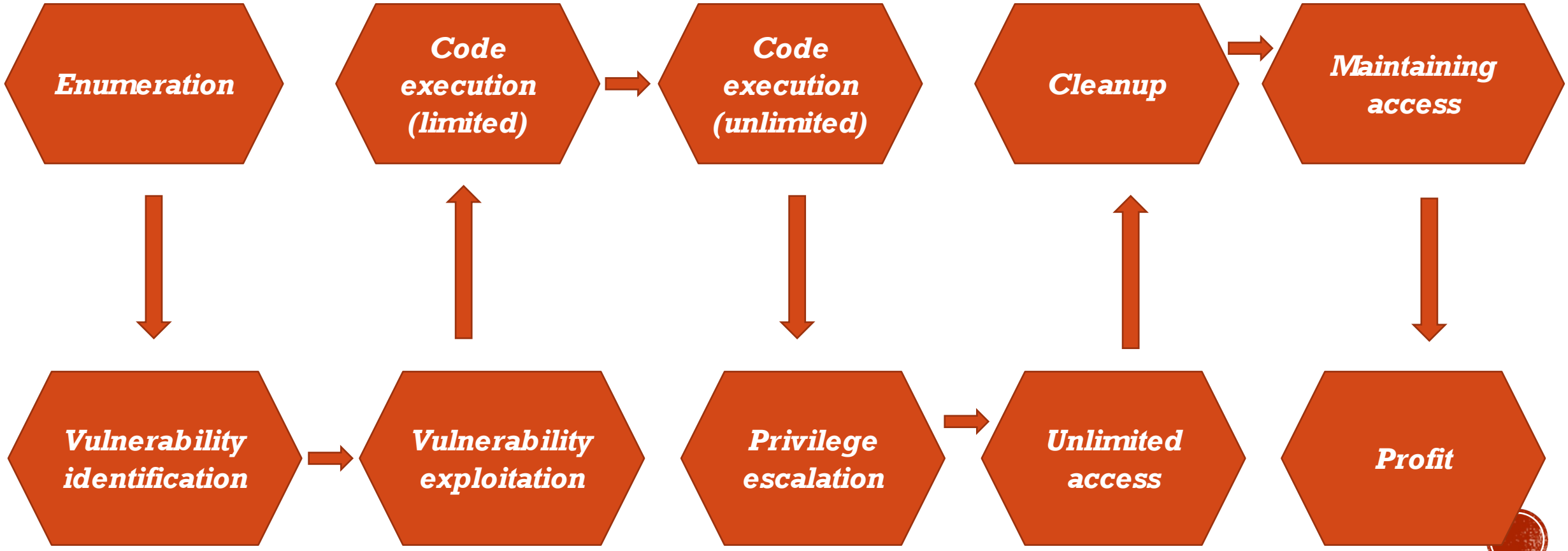
- „**To use something in a way that helps you**" – Cambridge Dictionary

- „**To use someone or something unfairly for your own advantage**"– Cambridge Dictionary

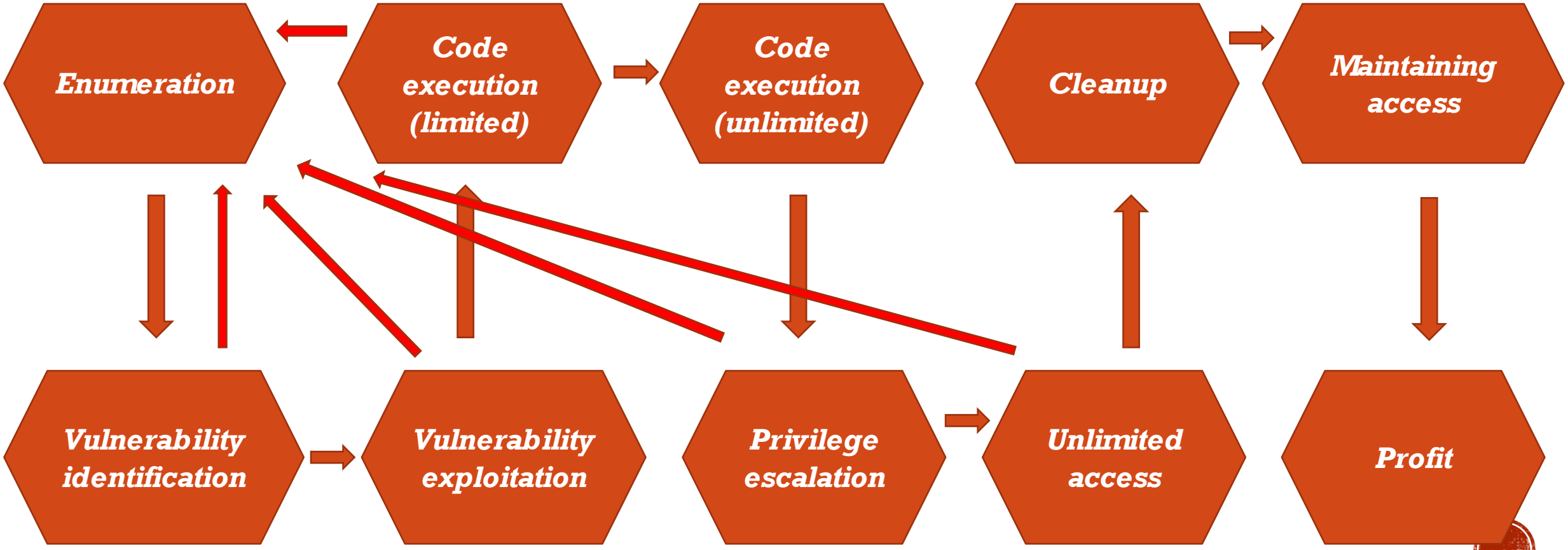
- „**An exploit is a piece of software, a chunk of data, or a sequence of commands that takes advantage of a bug or vulnerability to cause unintended or unanticipated behavior to occur on computer software, hardware, or something electronic (usually computerized). " – Wikipedia**
- **A tool/program to make use of a vulnerability**



THE HACKING CYCLE



THE HACKING CYCLE



WHAT IS VULNERABILITY ASSESSMENT (VA)?

- **Vulnerability assessment** is the process of identifying, quantifying, and prioritizing (or ranking) the vulnerabilities in a system.

- Vulnerability assessment is a well (well, better) defined process, but often confused with **penetration testing**, which is goal oriented, i.e., a pentester makes an effort to control critical systems and acquire access to sensitive data.



VULNERABILITY CLASSIFICATION

- ***Informational***
- ***Low***
- ***Medium***
- ***High***
- ***Critical***

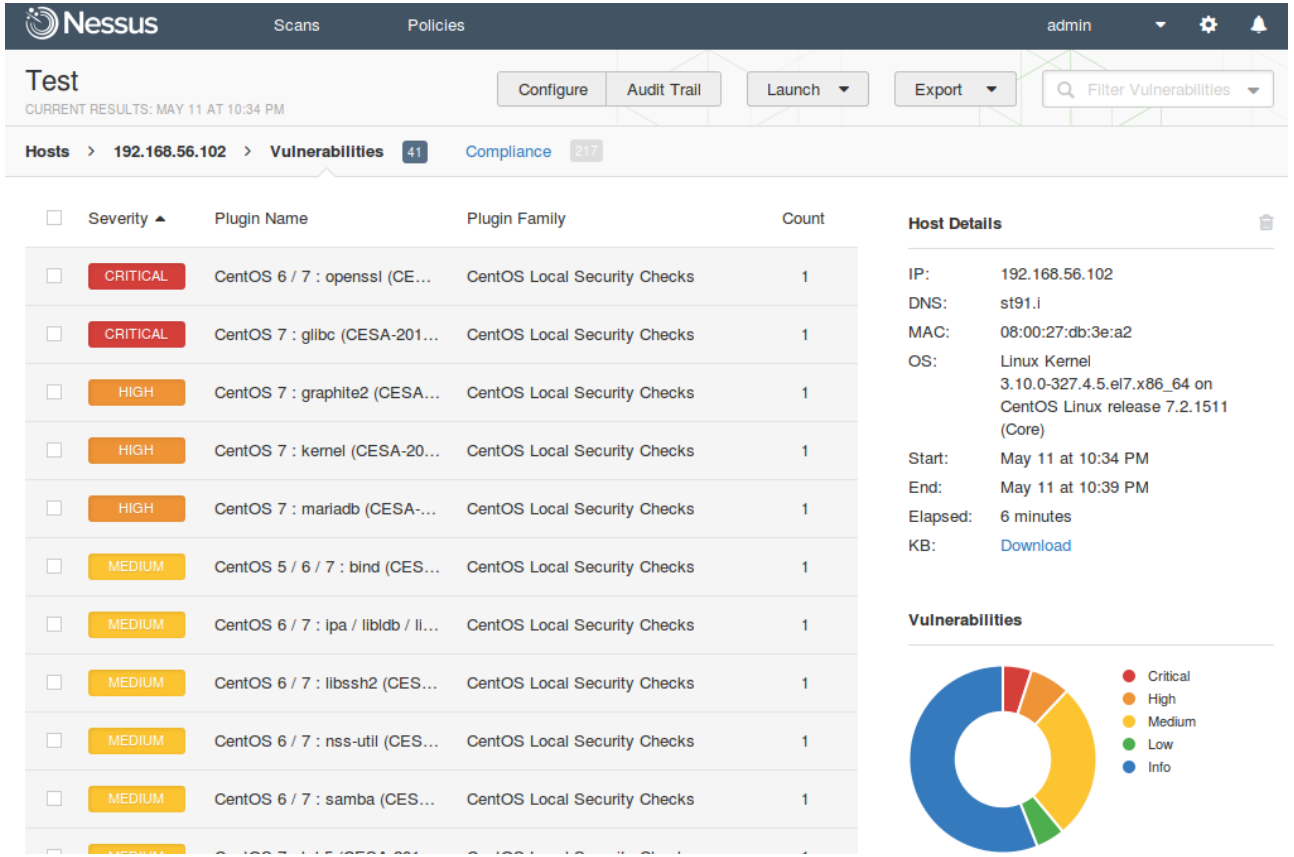
CVSS 3.0

THE VULNERABILITY DISCOVERY PROCESS

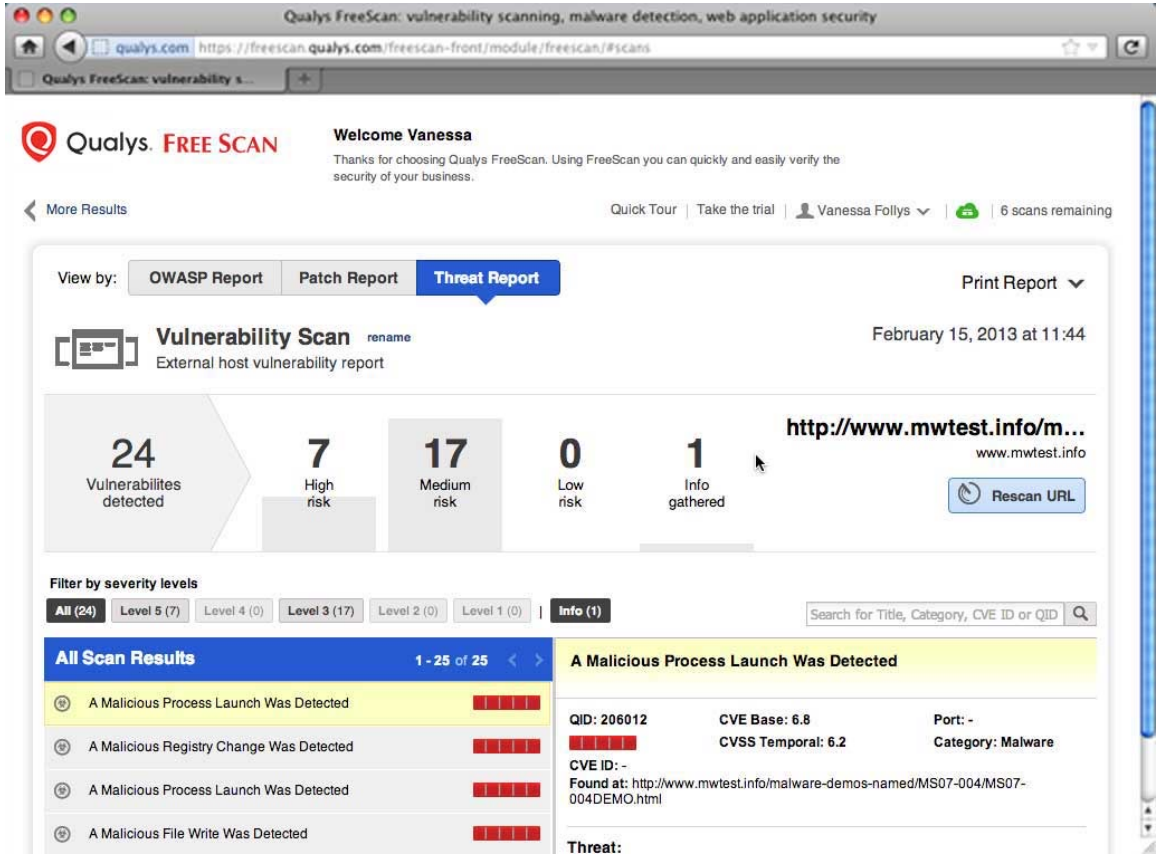
- Automated Tools
  - Qualys
  - Nessus
  - OpenVAS
- M anual
  - Vendor publications, CVEs
  - Service discovery (Nmap)



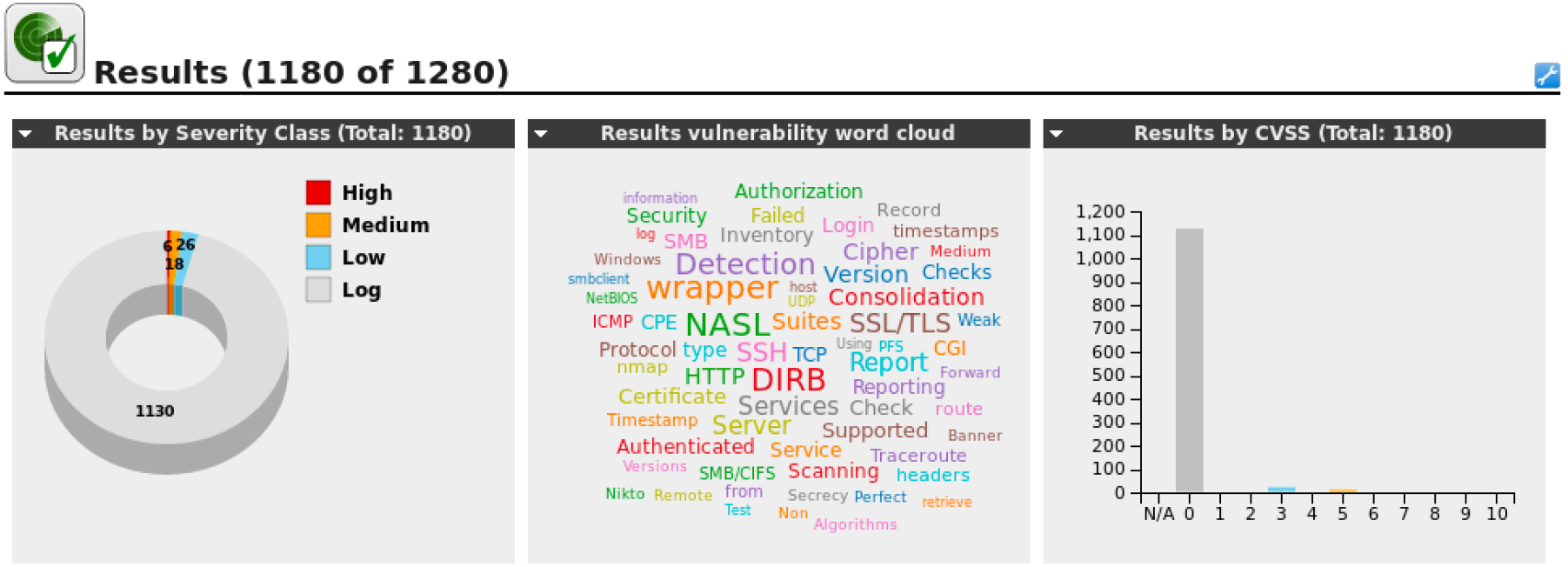
THE VULNERABILITY DISCOVERY PROCESS (NESSUS)



THE VULNERABILITY DISCOVERY PROCESS (QUALYS)



THE VULNERABILITY DISCOVERY PROCESS (OPENVAS)



1 - 10 of 1180

Vulnerability	Severity	QoD	Host	Location	Created
Microsoft Remote Desktop Protocol Detection	0.0 (Log)	80%	192.168.86.61	3389/tcp	Tue Oct 24 15:22:06 2017
DNS Server Detection (UDP)	0.0 (Log)	80%	192.168.86.7	53/udp	Tue Oct 24 15:14:47 2017
DNS Server Detection (UDP)	0.0 (Log)	80%	192.168.86.1	53/udp	Tue Oct 24 15:43:35 2017



THE VULNERABILITY DISCOVERY PROCESS (NMAP)

```
root@Cyborg999:~# nmap -A -T4 192.168.1.115

Starting Nmap 7.40 ( https://nmap.org ) at 2017-06-06 18:10 EDT
Nmap scan report for 192.168.1.115
Host is up (0.00054s latency).
Not shown: 997 filtered ports
PORT    STATE SERVICE       VERSION
135/tcp open  msrpc         Microsoft Windows RPC
139/tcp open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds?
MAC Address: 9E:B6:4C:0C:7D:87 (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed po
rt
Aggressive OS guesses: Microsoft Windows Server 2008 SP1 (90%), Microsoft Windows 10 build 10586 -
14393 (88%), Microsoft Windows Phone 7.5 or 8.0 (88%), Microsoft Windows 10 build 10586 (87%), Micr
osoft Windows Server 2008 R2 or Windows 8.1 (87%), Microsoft Windows 7 Professional or Windows 8 (8
7%), Microsoft Windows Vista SP0 or SP1, Windows Server 2008 SP1, or Windows 7 (87%), FreeBSD 6.2-R
ELEASE (87%), Microsoft Windows Embedded Standard 7 (86%), Microsoft Windows Vista SP2, Windows 7 S
P1, or Windows Server 2008 (86%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

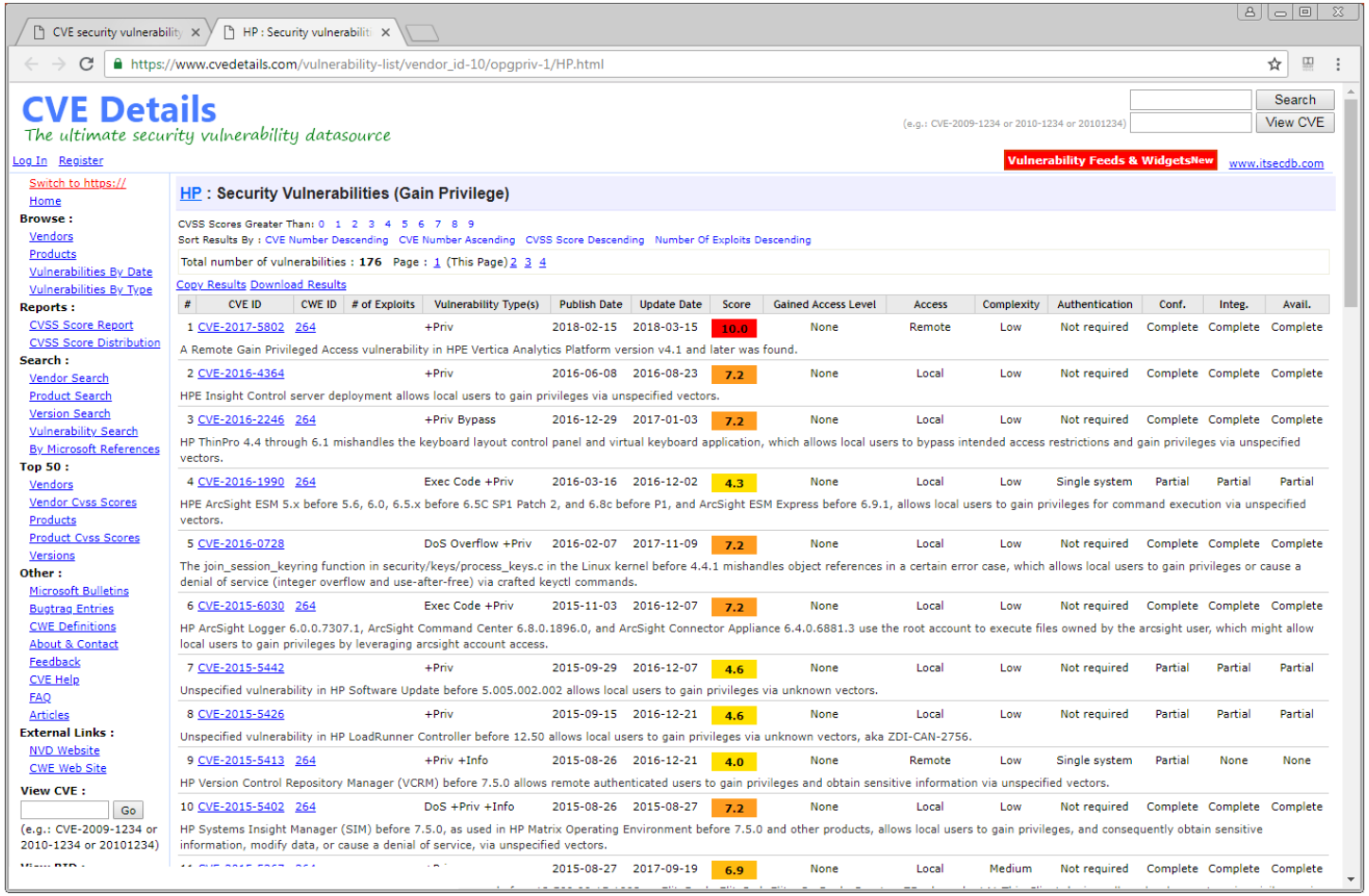
Host script results:
|_nbstat: NetBIOS name: DESKTOP-A3ECJHB, NetBIOS user: <unknown>, NetBIOS MAC: 9e:b6:4c:0c:7d:87 (u
nknown)
|_smbv2-enabled: Server supports SMBv2 protocol

TRACEROUTE
HOP RTT     ADDRESS
1   0.54 ms 192.168.1.115

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
 .
Nmap done: 1 IP address (1 host up) scanned in 61.91 seconds
```

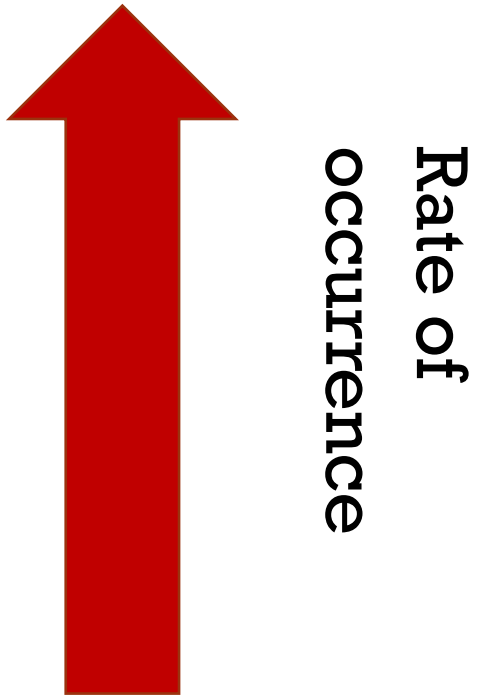


THE VULNERABILITY DISCOVERY PROCESS



COMMON TYPES OF SECURITY ISSUES

- Configuration issues
  - Default username and password
  - Exposed admin interface
  - Forgotten features
- Implementation errors
  - High-level errors
    - Improper authorization
    - Race conditions
    - Logic bugs
  - Low level implementation issues
    - Buffer overflow
    - Heap overflow



MITIGATING RISK

- ***Vulnerabilities are discovered, what do we do?***
- ***Ideally → Fix everything!***
- ***Reality → Mitigate risk***
- ***How? → Patches, configuration changes, policy updates, personnel training, extreme measures (rare, but should be more frequent)***
- ***A cycle rather than a linear process***



COMMON PROTOCOLS AND THEIR VULNERABILITIES



COMMON PROTOCOLS – (FTP, FTPS)

- Plaintext protocol (FTP) TCP/21
  - Used for file transfer (file transfer protocol)
- Complicated data flow
  - Control port, data port
  - Scanning the intranet!
- Default passwords
  - Including anonymous access
- No bruteforce protection
  - Credentials are sometimes tied into another system
    - Grants access to further resources!



COMMON PROTOCOLS – (FTP, FTPS)

- Implementation Errors
- Path handling issues "../"
- Excessive Read, Write permissions
- FTPS – SSL related issues



COMMON PROTOCOLS – (SMB/CIFS)

- TCP/445 (Since Windows 2000)
- Dominant in Windows systems especially before AD
- Used to share resources, files, printers, serial ports etc.
- Track record of bad security (recently notable MS-17-010)
- Often configured too loosely
- Can even lead to RCE



EXAMPLE 1 – ETERNAL BLUE

- Microsoft's implementation of SMB contained a crucial flaw → vulnerability
- The NSA weaponized the vulnerability instead of disclosing it
- The exploit got leaked
- Chaos ensued → Widespread exploitation, ransomware, WannaCry, NotPetya



COMMON PROTOCOLS – (NFS)

- TCP/2049
- Used for file sharing (Network File System)
- “no_root_squash” option is set for exports
- The “privileged ports” option is not set (not really relevant anymore)
- Client machines mount shares without “nosuid”



COMMON PROTOCOLS – (DNS)

- UDP/53, TCP/53
- Recursive protocol for resolving domain names
- Open Recursive DNS Servers Denial-of-Service (DoS)
  - Requesting queries with source IP spoofing
  - Large response leads to amplification
- Cache poisoning attack
  - Additional information section is cached by DNS server
    - Redirecting the name server
    - Redirecting the NS record



EXAMPLE 2 – BANRISUL BANK

- Brazilian bank had its entire DNS architecture compromised
- The attackers built an entire fake bank
- For multiple hours, all traffic was redirected to the fake bank
- Damage was immense



COMMON PROTOCOLS – (SNMP)

- TCP/161, UDP/161
- Default credentials, community string
  - Modification of system parameters
- Vendor specific MIBs
  - Even code execution may be possible



COMMON PROTOCOLS – (SSL)

- Weak Encryption Issues
  - Weak Ciphers are used by the server
    - No Cipher order is forced by the server
  - Weak protocol versions are allowed (SSLv1, SSLv2, SSLv3, TLS/1.0)
- Weak, bad certificate issues
  - Incomplete Chain of Trust
  - Weak hashing algorithm
- Weak parameters
  - Small encryption keys
  - Small DH parameters



COMMON PROTOCOLS – (SSL)

- Protocol Issues
  - Freak (Factoring RSA Export Keys)
  - Logjam (Export DH parameters)
  - BREACH, CRIME (Compression related issues)
  - POODLE (Padding Oracle attack)
  - Heartbleed (Memory leak)

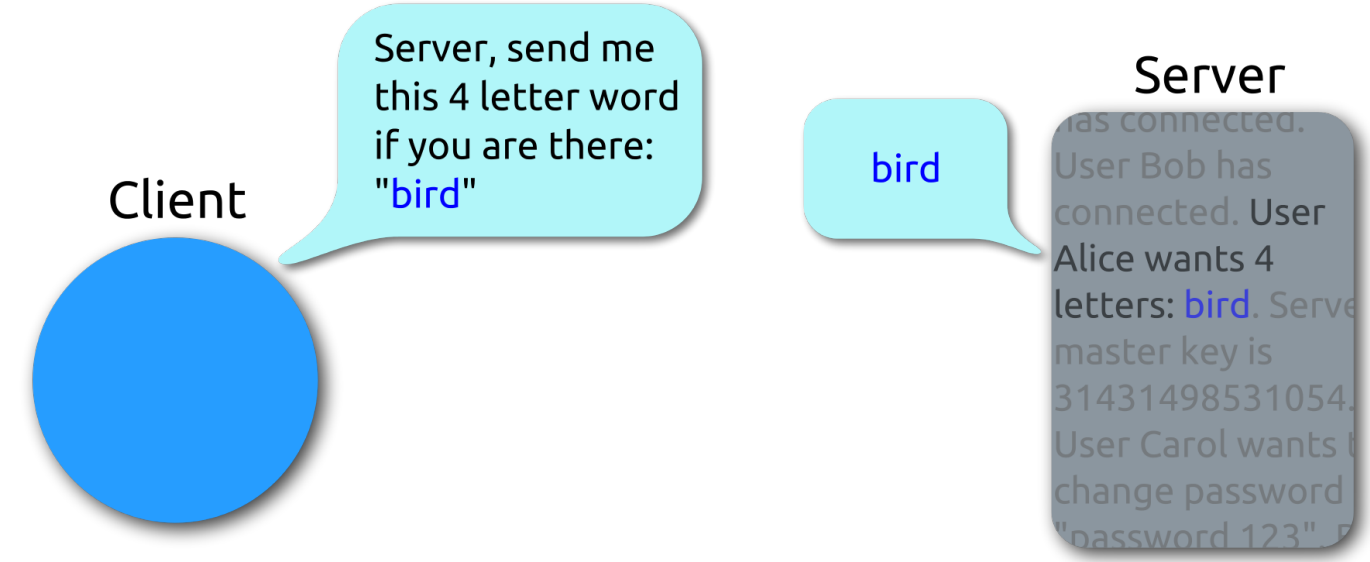


EXAMPLE 3 – HEARTBLEED

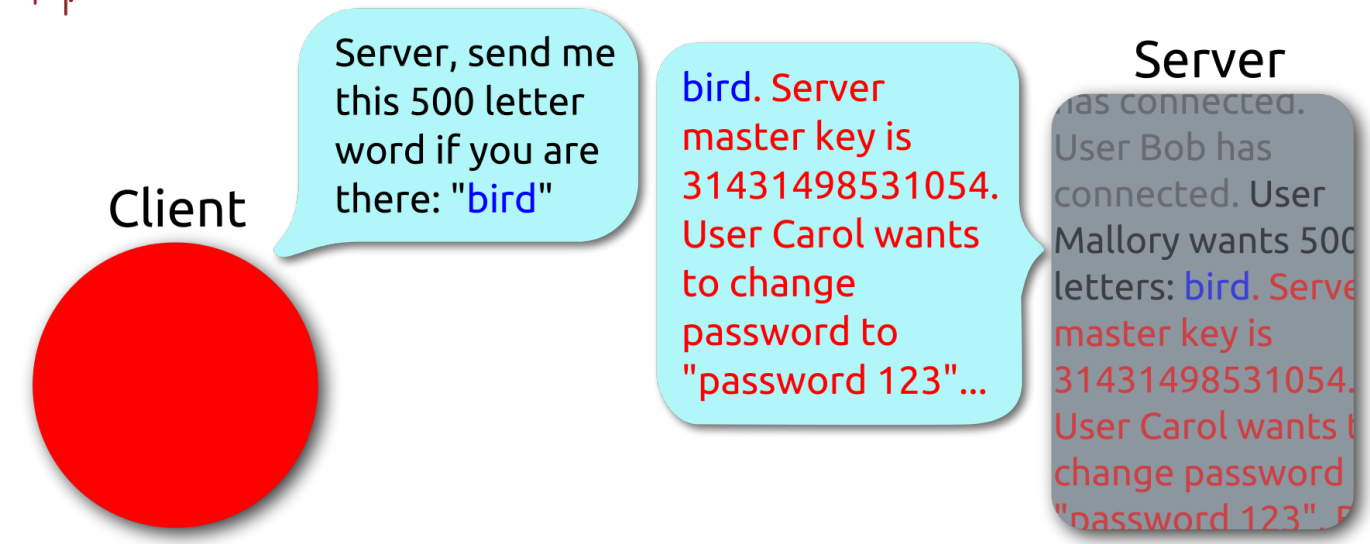
- Buffer overread vulnerability in OpenSSL
- Exploits the heartbeat keepalive functionality
- Lets attackers read chunks of server memory
- Difficult to control but can leak anything: passwords, secret keys etc.



Heartbeat – Normal usage



Heartbeat – Malicious usage



COMMON PROTOCOLS – (SSH)

- TCP/22
- Weak Cipher, User Enum, Bruteforce



COMMON PROTOCOLS – (TELNET)

- TCP/23
- Plaintext (MITM, Sniffing, Session Hijacking!!!)
- No brute force protection



COMMON PROTOCOLS – (HTTP, HTTPS)

- TCP/80, TCP/443
- Basic authentication is used
- Directory Traversal issues
- SQL injection
- File Upload
- Administration interface (Tomcat)
- Filename enumeration (IIS)
- Too many different issues to even count

